

Paper	Main contribution	Observation/results	Limitation or gap
Analysis of Software Supply Chain Security by Establishing Secure Design Properties — Okafor et al., 2022	Defines three supply-chain security properties: transparency, validity and separation	Existing techniques protect different portions of the supply chain, but no individual technique provides complete protection	Provides a conceptual model, not a complete developer-facing implementation
Reproducible Builds: Increasing the Integrity of Software Supply Chains — Lamb & Zacchiroli, 2022	Rebuilding the same source should produce an identical binary	Reproducible builds can reveal build-system tampering and establish source-to-binary correspondence	Real projects frequently contain timestamps, environment differences and nondeterministic build steps
SoK: Practical Detection of Software Supply Chain Attacks — Ohm & Stuke, 2023	Classifies practical approaches for detecting malicious packages and supply-chain attacks	Detection methods include metadata, static analysis, dynamic analysis and package comparison	Detection approaches remain fragmented, and scalable automated detection is still difficult
Supply Chain Insecurity: The Lack of Integrity Protection in SBOM Solutions — Özkan et al., 2024	Examines attacks that manipulate SBOM generation and consumption	Tested tools lacked sufficient integrity verification; dependency information could be altered so vulnerabilities were missed	Proposed integrity protection is not integrated with reachability analysis and practical CI/CD enforcement
A Reality Check on SBOM-based Vulnerability Management — Zhou et al., 2025	Studies SBOM generation and scanner accuracy over 2,414 repositories	Reports a 97.5% false-positive rate; function-call analysis pruned 63.3% of false alarms	Focuses mainly on SBOM accuracy and vulnerability reachability, not signing, deployment provenance or build verification